IT Asset Tracker

คู่มือ Blueprint ระดับ Production-Grade

ฉบับภาษาไทย

จัดทำเมื่อ 21 เมษายน 2569

เอกสารฉบับนี้กำหนด blueprint สำหรับยกระดับ repository GitHub nattapongsindhu/it-asset-tracker ให้เป็นระบบจัดการทรัพย์สิน IT ภายในองค์กรที่พร้อมใช้งานจริงบน Vercel และ Supabase

เนื้อหาอ้างอิงจากสถานะจริงของ repository ที่ตรวจสอบในเครื่อง และจัดโครงสร้างตาม workflow ด้านวิศวกรรมที่ต้องทำตามอย่างเคร่งครัด ได้แก่ /spec, /plan, /build, /test, /review และ /ship

1. สถานะปัจจุบันของระบบ

repository ปัจจุบันเป็น internal tool ที่ใช้งานได้จริงอยู่แล้ว ดังนั้นแนวทางที่ถูกต้องคือ migration และ hardening อย่างเป็นระบบ ไม่ใช่การเขียนใหม่ทั้งระบบแบบไม่มีการควบคุมความเสี่ยง

หัวข้อ	สถานะปัจจุบัน
Framework	Next.js 14 App Router
ภาษา	TypeScript 5
Styling	Tailwind CSS 3
Data Layer	Prisma 5 ร่วมกับ SQLite
Authentication	NextAuth v4 แบบ Credentials
Validation	Zod

1.1 Route ที่มีอยู่ในระบบ

- /login
- /dashboard
- /assets
- /assets/new
- /assets/[id]
- /assets/[id]/edit
- /audit

1.2 กฎธุรกิจที่ยืนยันแล้วจากโค้ดปัจจุบัน

- ระบบมี 2 บทบาท คือ ADMIN และ STAFF
- สถานะของทรัพย์สินคือ IN_STOCK, ASSIGNED, IN_REPAIR และ RETIRED
- Staff ไม่มีสิทธิ์สร้าง แก้ไข หรือลบ asset
- หน้า Audit Log เป็นสิทธิ์ของ Admin เท่านั้น
- ทุก mutation สำคัญมีการตรวจสิทธิ์ฝั่ง server ก่อนเขียนฐานข้อมูล
- หมายเหตุของ asset แสดงผลเป็น plain text เพื่อลดความเสี่ยง XSS

1.3 ข้อจำกัดของระบบปัจจุบัน

- ประวัติการมอบหมาย asset ยังถูกเก็บแบบแบนใน assignedUserId ของ asset
- งานซ่อมบำรุงยังถูกแทนด้วย status และ notes เป็นหลัก
- ยังไม่มีระบบจัดเก็บไฟล์สำหรับใบเสร็จ ใบรับประกัน หรือรูปภาพอุปกรณ์
- SQLite และ local credentials auth ยังไม่เหมาะเป็น backbone ของ production บน Vercel

1.4 บัญชีสำหรับ demo และการทดสอบ

บทบาท	credential ปัจจุบันจาก seed	credential ที่ต้องใช้ใน blueprint production
Admin	admin@company.com / admin123	admin@company.com / admin123
Staff	staff@company.com / staff123	staff@company.com / staff123

2. เป้าหมายของ production version

- deploy ระบบบน Vercel
- ใช้ Supabase Hybrid Auth สำหรับทั้ง Email + Password และ Magic Link
- เปิดใช้ Magic Link เฉพาะกับผู้ใช้ที่มีบัญชีอยู่แล้ว และไม่เปิด public signup
- ใช้ Supabase Postgres เป็นฐานข้อมูลหลัก
- ใช้ Supabase Storage สำหรับไฟล์ของ asset
- คง RBAC และ auditability ให้เป็นข้อกำหนดหลัก
- รักษาพฤติกรรมทางธุรกิจเดิมที่ถูกต้อง พร้อมยกระดับความพร้อมใช้งานจริง

3. สถาปัตยกรรมเป้าหมาย

Layer	ทางเลือกสำหรับ production	เหตุผล
Frontend	Next.js App Router	รักษาแนวทางเดิมของแอปและเหมาะกับ Vercel

Layer	ทางเลือกสำหรับ production	เหตุผล
Hosting	Vercel	deploy ง่าย มี preview environment และเหมาะกับ Next.js
Authentication	Supabase Auth	ลดความซับซ้อนของ auth และเชื่อมกับ data platform ได้ตรงกว่า
Database	Supabase Postgres	เหมาะกับข้อมูลเชิงสัมพันธ์ของ asset, assignment และ audit log
Storage	Supabase Storage	รองรับไฟล์ใบเสร็จ ใบรับประกัน และภาพอุปกรณ์
Security	Supabase RLS + server checks	ป้องกันข้อมูลทั้งที่ชั้นฐานข้อมูลและชั้นแอปพลิเคชัน

หลักการ migration ที่แนะนำคือค่อย ๆ เปลี่ยนไปสู่ stack ที่เรียบง่ายกว่าใน production โดยลดบทบาทของ Prisma + SQLite + NextAuth ออกจากเส้นทาง production สุดท้าย เว้นแต่จะมีเหตุผลชัดเจนใน /spec ว่าต้องมี bridge ชั่วคราว

4. โครงสร้างข้อมูลที่แนะนำ

schema สำหรับ production ควรขยายจากของเดิมเพื่อเก็บประวัติ รองรับการอัปโหลดไฟล์ และทำให้ audit มีคุณภาพมากขึ้น

4.1 profiles

คอลัมน์	ชนิดข้อมูล	วัตถุประสงค์
id	uuid	primary key ที่ผูกกับ auth.users.id

คอลัมน์	ชนิดข้อมูล	วัตถุประสงค์
email	text	อีเมลที่ไม่ซ้ำกัน
full_name	text	ชื่อสำหรับแสดงผล
role	text	ADMIN หรือ STAFF
department	text nullable	ข้อมูลหน่วยงานถ้ามี
created_at	timestamptz	เวลาที่สร้างข้อมูล

4.2 assets

คอลัมน์	ชนิดข้อมูล	วัตถุประสงค์
id	uuid	primary key
asset_tag	text	รหัสทรัพย์สินที่ไม่ซ้ำ
category	text	เช่น laptop, monitor, keyboard, accessory
brand / model	text	ข้อมูลหลักของอุปกรณ์
serial_number	text nullable	หมายเลข serial ถ้ามี
status	text	IN_STOCK, ASSIGNED, IN_REPAIR, RETIRED
condition	text	NEW, GOOD, FAIR, DAMAGED
purchase_date / purchase_cost	date / numeric nullable	ข้อมูลด้านการจัดซื้อ
vendor / location	text nullable	ข้อมูลการปฏิบัติงาน
warranty_expiry	date nullable	วันหมดประกัน
notes	text nullable	หมายเหตุแบบ plain text

คอลัมน์	ชนิดข้อมูล	วัตถุประสงค์
created_by / created_at / updated_at	uuid + timestamptz	เจ้าของข้อมูลและเวลา

4.3 asset_assignments

คอลัมน์	ชนิดข้อมูล	วัตถุประสงค์
id	uuid	primary key
asset_id	uuid	อ้างอิง assets.id
user_id	uuid	อ้างอิง profiles.id
assigned_at	timestamptz	เวลามอบหมาย
returned_at	timestamptz nullable	เวลาคืนอุปกรณ์
assigned_by	uuid	ผู้ดำเนินการมอบหมาย
note	text nullable	หมายเหตุการมอบหมาย

4.4 maintenance_logs

คอลัมน์	ชนิดข้อมูล	วัตถุประสงค์
id	uuid	primary key
asset_id	uuid	อ้างอิง assets.id
issue	text	รายละเอียดปัญหา
status	text	OPEN, IN_PROGRESS, RESOLVED
vendor / cost	text / numeric nullable	ข้อมูลการซ่อม
opened_at / resolved_at	timestamptz	ช่วงเวลาของงานซ่อม
note	text nullable	หมายเหตุการซ่อม

คอลัมน์	ชนิดข้อมูล	วัตถุประสงค์
created_by	uuid	ผู้เปิดรายการซ่อม

4.5 asset_files และ audit_logs

ตาราง	field สำคัญ	วัตถุประสงค์
asset_files	asset_id, file_name, file_path, file_type, uploaded_by, created_at	เก็บ metadata ของไฟล์ที่อยู่ใน Supabase Storage
audit_logs	actor_id, action, entity_type, entity_id, detail jsonb, created_at	เก็บเหตุการณ์สำคัญของระบบแบบมีโครงสร้าง

5. นโยบายความปลอดภัยและสิทธิ์การเข้าถึง

- เปิดใช้ Row Level Security กับทุกตารางธุรกิจหลัก
- การซ่อนปุ่มหรือเมนูใน UI ถือเป็นเพียง convenience ไม่ใช่ authorization
- service-role key ต้องอยู่ฝั่ง server เท่านั้น
- ทุกการเขียนข้อมูลต้องมี validation ฝั่ง server แม้จะมี RLS อยู่แล้ว
- audit logging ต้องถูกควบคุมจากฝั่ง server และเป็นข้อบังคับสำหรับเหตุการณ์สำคัญ

5.1 สิทธิ์ของ Admin

- อ่านและจัดการ asset, assignment, maintenance, file และ audit log ได้ทั้งหมด
- สร้าง แก้ไข คืน ปลดระวาง และลบข้อมูลในกรณีที่ระบบอนุญาตอย่างชัดเจน

5.2 สิทธิ์ของ Staff

- อ่านข้อมูล profile ของตนเอง
- อ่าน asset ที่ถูกมอบหมายให้ตนเอง และ scope เพิ่มเติมที่ระบุไว้ชัดเจนใน product spec
- ไม่มีสิทธิ์ดู audit log รวมของระบบ และไม่มีสิทธิ์ทำ mutation ฝั่ง admin

6. สัญญาการทำงานตาม workflow

Phase	เป้าหมาย	กฎที่ห้ามข้าม
/spec	นิยาม technical specification	Spec ต้องมาก่อน code และห้ามเริ่ม implementation
/plan	แตกงานเป็น task ที่พึ่งพากันอย่างถูกลำดับ	ทุก task ต้องมี definition of done
/build	พัฒนาเป็น slice เล็กทีละส่วน	ต้อง verify แต่ละ slice ก่อนขึ้นงานถัดไป
/test	พิสูจน์ว่างานใช้ได้จริง	ต้องมีคำสั่งที่รันและหลักฐานจริง
/review	ตรวจคุณภาพด้าน readability, security, performance	ต้อง flag code smell และ over-engineering
/ship	เตรียม rollout ขึ้น production	ต้องมี rollback plan เสมอ

6.1 ลำดับ build slice ที่แนะนำ

1. ตั้งค่า Supabase project, SQL schema และ RLS policy
2. ย้าย auth และ route protection
3. ย้ายเส้นทางอ่านข้อมูล asset, dashboard และ core CRUD
4. เพิ่มประวัติการมอบหมายผ่าน asset_assignments
5. เพิ่ม maintenance workflow
6. เพิ่ม file upload บน storage
7. ปรับปรุง audit และเอกสารประกอบ

6.2 Definition of Done ของแต่ละ phase

- /spec เสร็จเมื่อ current state, target state, migration risk และ scope ถูกนิยามชัดเจน
- /plan เสร็จเมื่อ task มีขนาดเล็ก เรียงตาม dependency และมี verification กำกับ

- /build เสร็จเป็นราย slice ได้ต่อเมื่อพิสูจน์แล้วว่า slice นั้นทำงานจริง
- /test เสร็จเมื่อ proof แทนที่ assumption
- /review เสร็จเมื่อความเสี่ยงสำคัญถูกแก้หรือถูกบันทึกอย่างตรงไปตรงมา
- /ship เสร็จเมื่อ deployment และ rollback ปลอดภัยในเชิงปฏิบัติการ

7. การทดสอบและความพร้อมสำหรับการปล่อยระบบ

พื้นที่ตรวจสอบ	หลักฐานที่ต้องมี
Lint	npm run lint ผ่าน
Build	npm run build ผ่าน
Auth	Admin และ Staff เข้าสู่ระบบได้
RBAC	Staff ถูกบล็อกจาก action และ route ของ admin
Assets	สร้าง แก้ไข ดู และค้นหาได้ถูกต้อง
Assignments	การมอบหมายและคืน asset ถูกต้อง
Maintenance	การเปิดและปิดงานซ่อมถูกต้อง
Storage	อัปโหลดไฟล์และการจำกัดสิทธิ์ทำงานถูกต้อง
Audit	mutation สำคัญสร้าง audit record ได้
RLS	การเข้าถึงที่ไม่ได้รับอนุญาตถูกปฏิเสธ

7.1 Manual critical path ที่ต้องตรวจ

- เข้าสู่ระบบเป็น admin ด้วย admin@company.com / admin123
- เข้าสู่ระบบเป็น staff ด้วย staff@company.com / staff123
- ทดสอบขอและใช้งาน Magic Link สำหรับผู้ใช้ที่มีสิทธิ์อยู่แล้ว
- ยืนยันว่า admin เข้า /audit ได้
- ยืนยันว่า staff เข้า /audit หรือทำ action แบบ admin ไม่ได้
- สร้างและแก้ไข asset ด้วยบัญชี admin

- มอบหมาย asset ให้ staff และตรวจ scope การมองเห็น
- อัปโหลดไฟล์ให้ asset
- เปิด maintenance record และปิดงานซ่อม
- ตรวจว่ามี audit log สำหรับเหตุการณ์สำคัญ

8. Environment blueprint และขอบเขต MVP

ตัวแปร	หน้าที่
NEXT_PUBLIC_SUPABASE_URL	URL ของ Supabase project
NEXT_PUBLIC_SUPABASE_ANON_KEY	anonymous key ที่ใช้ได้ฝั่ง browser
SUPABASE_SERVICE_ROLE_KEY	key สำหรับงานฝั่ง server เท่านั้น
NEXT_PUBLIC_SITE_URL	URL หลักของแอป
DATABASE_URL	การเข้าถึง Postgres โดยตรงสำหรับ migration tooling ถ้าจำเป็น

8.1 สิ่งที่ต้องอยู่ใน MVP

- ระบบ login และ route protection
- บทบาท Admin และ Staff
- dashboard overview
- asset list, detail, create และ edit
- assignment history
- maintenance log
- audit logging
- file upload support
- เอกสาร deployment บน Vercel

8.2 สิ่งที่ตัดออกจาก MVP อย่างชัดเจน

- barcode หรือ QR scanning
- multi-tenant architecture
- workflow approvals
- real-time subscriptions

- AI assistant features
- analytics dashboard ที่ซับซ้อนเกินจำเป็น

9. Definition of Done ของโปรเจกต์และขั้นตอนถัดไป

- deploy บน Vercel ได้จริง
- Supabase Hybrid Auth ใช้งานได้จริง
- Supabase Postgres schema และ RLS policy ถูกใช้งานแล้ว
- Admin login ใช้ admin@company.com / admin123 ได้
- Staff login ใช้ staff@company.com / staff123 ได้
- ทั้ง Password และ Magic Link ใช้งานได้สำหรับผู้ใช้ที่ได้รับอนุญาต
- Staff ถูกบล็อกจากพฤติกรรมแบบ admin
- workflow ของ asset, maintenance, file และ audit ถูก verify แล้ว
- เอกสาร setup และ deployment เป็นปัจจุบัน
- มีหลักฐานจาก /test และผลจาก /review ครบ

หาก /test และ /review ยังไม่ครบ สถานะที่ถูกต้องคือ NOT READY

1. ล็อก scope ของ production ด้วย /spec ให้ชัดเจน
2. ตัดสินใจว่าจะถอด Prisma ทันที หรือใช้ bridge ชั่วคราว
3. เริ่มจาก Supabase SQL schema และ RLS policy ก่อน
4. แทนที่ NextAuth ด้วย Supabase Auth และทำ route protection ใหม่
5. คง seed และ QA credential ให้ staff ใช้ staff123
6. ย้ายประวัติการมอบหมายไปที่ asset_assignments
7. ทำ /test, /review และ /ship ให้ครบก่อนประกาศว่างาน migration เสร็จ